RECAP. THEMES: &CASE EXAMPLE.

By Muhammad Moosa Khan

COURSE OVERVIEW

THREAD MODELING

CYBER ATTACKS AND ADVISORY METHODS

WEB SECURITY. OWASP 10.

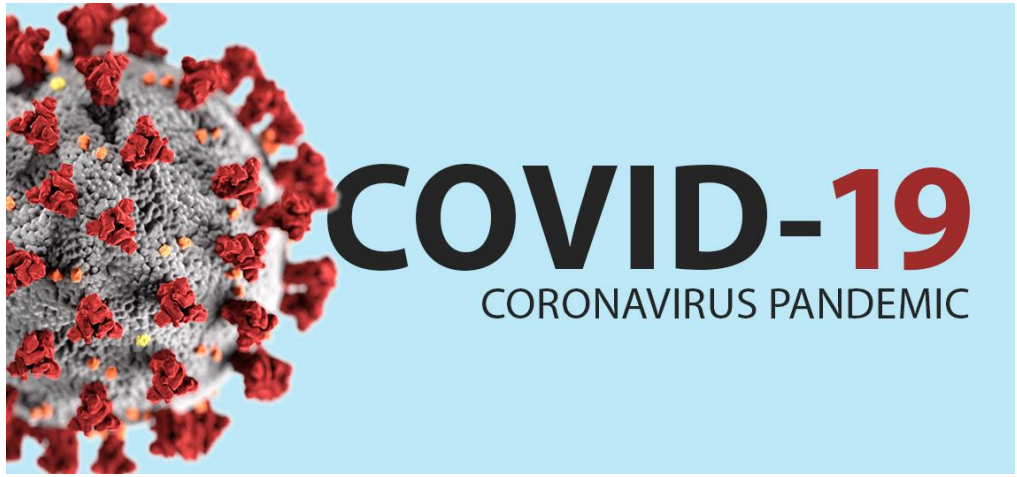
ENCRYPTION AND SECURE COMMUNICATION

IDENTITY AND AUTHENTICATION

NEW DEVELOPEMENTS. OSINT.

THREAT MODELING

- Threat modeling is a process used to identify security and privacy risks
- If you remember there were Four Key Questions
- It helps recognize risks early
- Anyone concerned about privacy, safety, or security



https://www.threatmodelingmanifesto.org/

CYBER KILL CHAIN, RULES AND DEFENSE

- It describes the 7 steps attackers follow when performing a cyber attack.
- This helps organizations to stop these attacks before any damage is done.
- GRC is a framework combines all three to ensure a company is actually following the law and identifying the right risks.
- Examples of simple safety practices include:

1. Use unique passwords
2. Enable 2FA.

https://www.microsoft.com/en-us/security/business/security-101/what-is-cyber-kill-chain#:~:text=The%20cyber%20kill%20chain%20defines,and%20how%20they%20evade%20detection.
https://www.legitsecurity.com/aspm-knowledge-base/grc-in-cybersecurity

WEB SECURITY AND OWASP 10

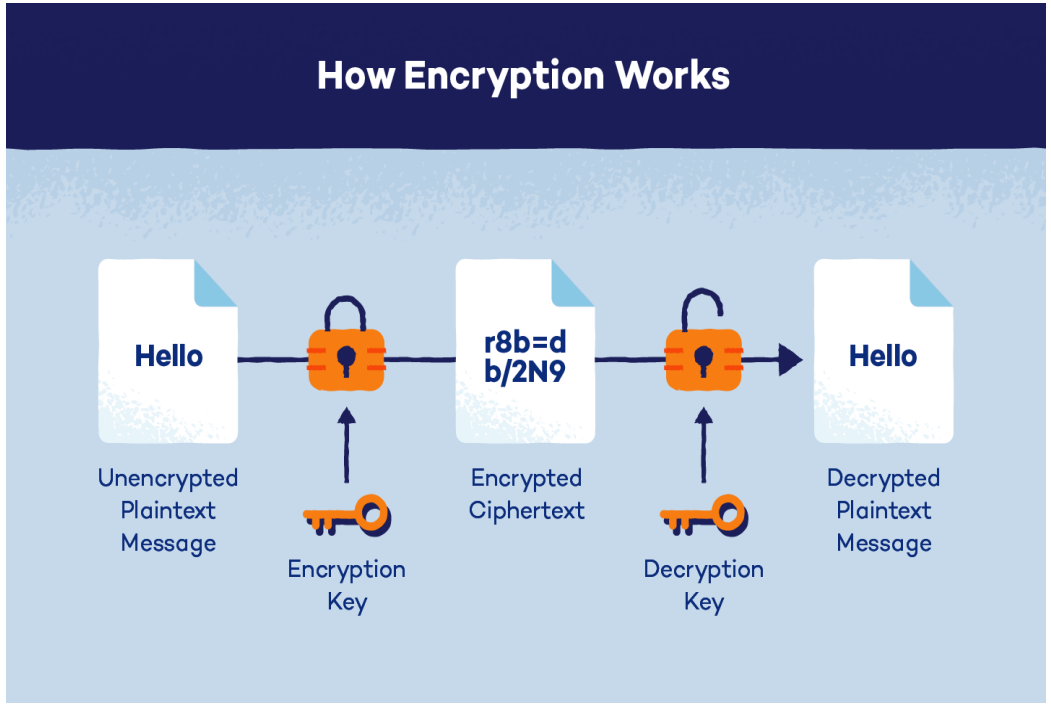
- **OWASP** is a foundation that works to improve software security.
- It provides us with a list of 10 most critical web application security risks.

1. Broken Access Control
2. Security Misconfiguration
3. Vulnerable and outdated components

- **Web security** focuses on protecting websites and web applications from cyber attacks.
- It aims to protect user data, systems, and services

OWASP TOP 10

https://owasp.org/Top10/2021/A00_2021_Introduction/
https://www.proofpoint.com/us/threat-reference/web-security



ENCRYPTION AND COMMUNCATION SECURITY

- Encryption is the process of converting plain text into cyphertext
- Sensitive information is protected from unauthorized access.
- Symmetric Encryption uses one shared key to encrypt and decrypt data
- Asymmetric Encryption uses two keys a public key and a private key.

https://www.ibm.com/think/topics/encryption#17494633

FOR SECURE COMMUNICATION

- **GPG**

1. A tool that helps you **encrypt** and **sign** your data.

- A **public key** (which you can share with anyone).
- A **private key** (which is kept secret and only for you to use).

- **SSH**

1. SSH is a protocol used to **securely connect to remote computers**.

- Secure remote login
- Secure file transfers (SFTP & SCP)

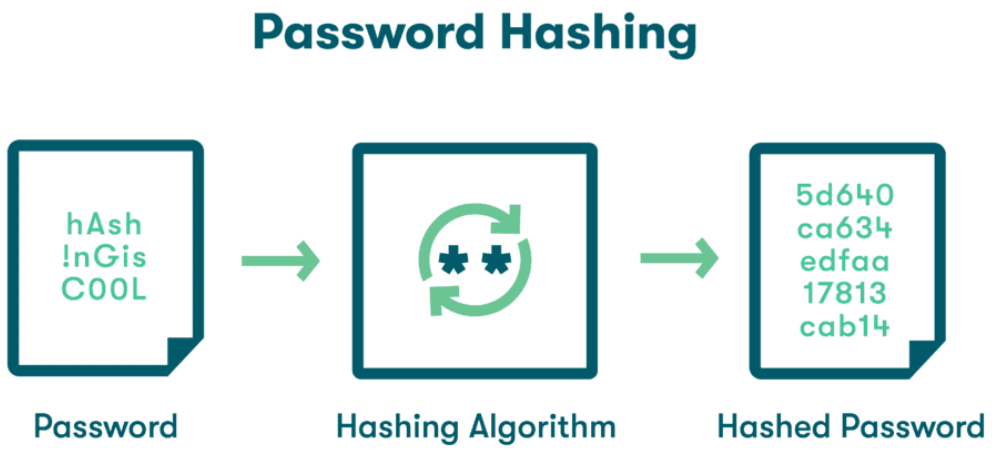
https://terrazone.io/what-is-gpg/

https://www.encryptionconsulting.com/everything-you-need-to-know-about-ssh/

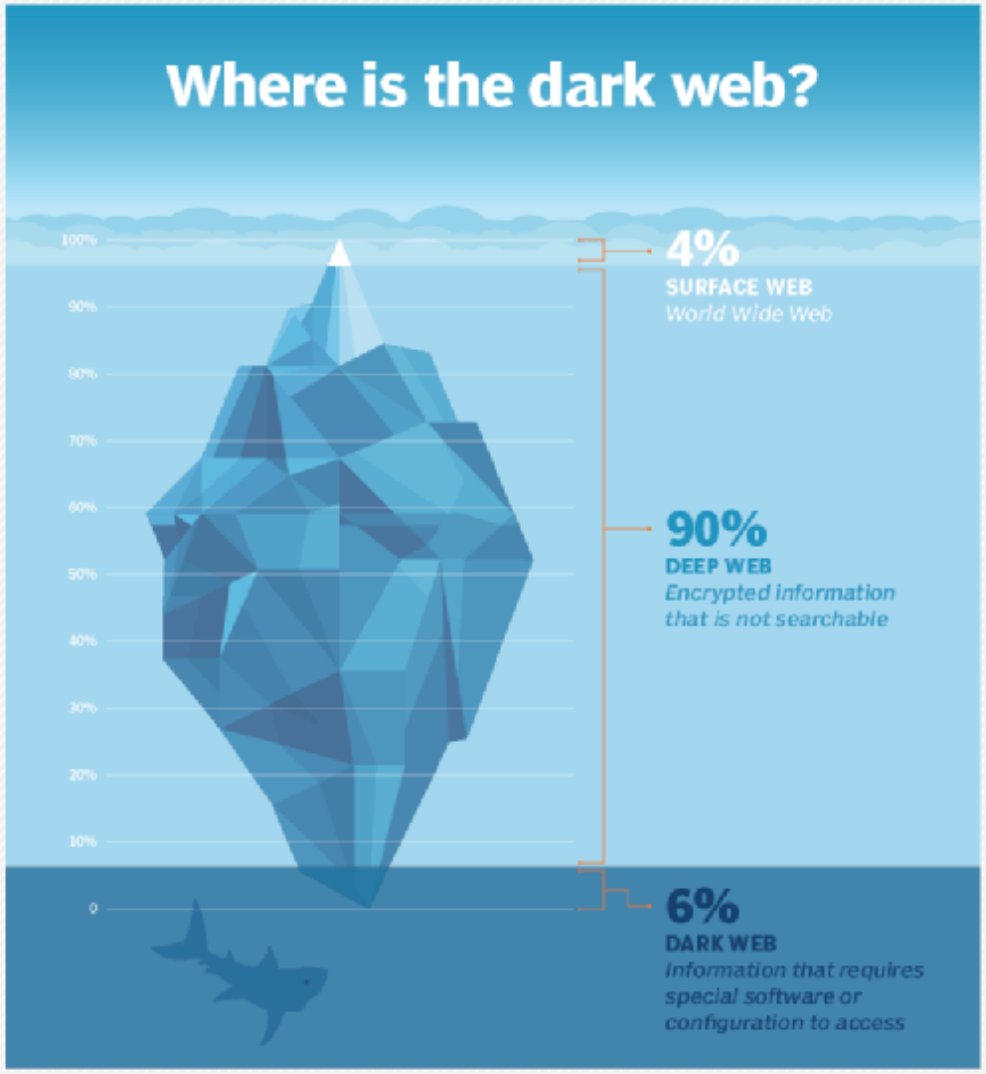
HASHES, IDENTITY, PASSWORDS AND AUTHENTICATION

- Hash is a function that converts data into a string of characters.
- It is a one - way function, meaning it can not be easily reversed back to original.
- It protects user's passwords even if a database is stolen.
- Authentication includes several checks for identity like:

1. Smartphones
2. Face IDs
3. MFA



https://www.infobip.com/glossary/password-hashing#how-is-password-hashing-used-to-grant-access



OSINT & Darknet

- **OSINT** means gathering publicly available data to analyze about any threats.
- It is often used in cybersecurity and by intelligence agencies.
- **Darknet** is a part within the internet that is not easily accessible. It require special software to access.
- Many activities on the Darknet are illegal.
- **TOR** is a network that can used to gain access to the Darknet.
- It protects user's IP address through multiple encrypted layers.

https://www.ibm.com/think/topics/osint
https://en.wikipedia.org/wiki/Darknet
https://en.wikipedia.org/wiki/Tor_(network)

REAL LIFE CASE EXAMPLE

- Happened in 2013
- Retail company Target suffered a major cyberattack.
- Hackers stole credit card information for about 40 million customers
- Even personal data of 70 million people was compromised/exposed.
- Cybercriminals were growing
- Major security shifts.
- They suffered a heavy financial and reputational blow out of nowhere

How did it take place?

- Attackers first targeted a **third-party contractor** which was "Fazio Mechanical Services".
- Hackers obtained credentials used by the vendor to access a Target web application.
- Once they gained access malware was installed on Target's point-of-sale systems (cash register systems).
- This allowed them to capture sensitive customer information, including payment card details and personal data.

Security problems

- Broken access control, attackers moved inside the network.
- Weak network segmentation, attackers accessed sensitive systems.

Lessons learned: Indeed, a wake-up call

- Network segmentation
- Monitor and respond to security alerts
- Secure third-party vendor access

https://frameworksecurity.com/post/the-target-breach-a-historic-cyberattack-with-lasting-consequences
https://redriver.com/security/target-data-breach

Thank you!